

BlackCat / ALPHV

Double Extortion Incident

TryHackMe | SOC Simulator | Medium Difficulty

ORGANISATION	PawPressMe (pawpress.me)
INCIDENT DATE	04/29/2026
DURATION	~54 minutes (18:25 - 19:16 UTC)
THREAT ACTOR	BlackCat / ALPHV (RaaS)
TOTAL ALERTS	11 (10 TP / 1 FP)
SCORE	100% - Perfect

10

TRUE POSITIVES

1

FALSE POSITIVE

5

HOSTS HIT

OVERVIEW

This write-up documents a completed TryHackMe SOC Simulator challenge at Medium difficulty, simulating a full BlackCat/ALPHV ransomware-as-a-service intrusion against a fictional organisation called PawPressMe. The incident unfolded in under 55 minutes and followed the classic double extortion playbook: credential theft from a third-party breach, SSH-based initial access, post-exploitation enumeration, privilege escalation, covert data exfiltration, public extortion notice, and automated ransomware deployment across Windows endpoints.

The analyst role required triaging 11 alerts in chronological order, correctly identifying 10 true positives and 1 false positive, and correlating them into a coherent incident chain. All 11 verdicts were judged correct, achieving a 100% score.

Total Alerts	True Positives	False Positives	Hosts Compromised	Score
11	10	1	5	100%

INCIDENT TIMELINE SUMMARY

Time (UTC)	Alert	Event	Verdict	Severity
18:25:02	Alert 01	Credential Leak - Four pawpress.me Accounts Exposed	TP	Medium
18:26:38	Alert 02	SSH Credential Stuffing Against paw-backup	TP	High
18:29:41	Alert 03	Post-Exploitation Enumeration on paw-backup	TP	High
18:33:02	Alert 04	Failed su to pawbackup - Privilege Escalation Attempt	TP	High
18:38:21	Alert 05	Covert SFTP Exfiltration as pawbackup	TP	Critical
18:47:54	Alert 06	ChatGPT Installer.exe Downloaded on PAW-TOM	FP	Informational
18:53:22	Alert 07	BlackCat/ALPHV Public Extortion Post - 5-Day Deadline	TP	Critical
19:03:52	Alert 08	RunRansom Scheduled Task Deployed on PAW-TOM	TP	Critical
19:08:09	Alert 09	RunRansom Deployed on PAW-LEO - Lateral Deployment Confirmed	TP	Critical
19:12:26	Alert 10	RunRansom Deployed on PAW-MARIE	TP	Critical
19:16:43	Alert 11	RunRansom Deployed on PAW-TABITHA - Mass Encryption Phase 1	TP	Critical

ALERT-BY-ALERT ANALYSIS

Alert 01 18:25:02 UTC		DarkSearchMe / WatchingCatsLounge.thm	TRUE POSITIVE
Title	Credential Leak - Four pawpress.me Accounts Exposed		
MITRE	T1589.001 - Gather Victim Identity Information		
Severity	Medium		
Analysis	DarkSearchMe detected four corporate pawpress.me addresses in an external credential dump from WatchingCatsLounge.thm. Accounts exposed: leo, marie, tabitha, and tom - all with plaintext passwords recovered. Tom's password ILoveLasagn@ was assessed as weak with high reuse likelihood. No internal telemetry was available, consistent with an externally-sourced breach. This alert was the seed of the entire incident chain - from here, the attacker had everything needed to begin credential stuffing against corporate infrastructure.		
Actions	Force password resets for all four accounts immediately. Enforce MFA. Review login history across SSO, VPN, and email for anomalous access from any of the four accounts.		

Alert 02 18:26:38 UTC		paw-backup	TRUE POSITIVE
Title	SSH Credential Stuffing Against paw-backup		
MITRE	T1110.004 - Credential Stuffing		
Severity	High		
Analysis	96 seconds after the credential dump alert, IP 194.50.16.198 launched automated SSH attacks against paw-backup targeting leo, marie, and tabitha - all flagged as invalid users by sshd. Tom was absent from the failed auth logs. Since sshd only logs rejected attempts at pre-auth stage, tom's absence from failures strongly indicated a silent successful authentication. Corroborated across both auth.log (auth-2) and journald/sysmon with consistent SEQNUM progression, ruling out any logging artefact.		
Actions	Block 194.50.16.198 at perimeter and host firewall immediately. Verify whether tom has an active session on paw-backup. Confirm none of the four leaked accounts exist as local Linux users on any SSH-accessible host in the environment.		

Alert 03 18:29:41 UTC		paw-backup	TRUE POSITIVE
Title	Post-Exploitation Enumeration on paw-backup		
MITRE	T1087.001 - Account Discovery: Local Account		
Severity	High		
Analysis	Sysmon EventID 1 captured tom running cat against six passwd file paths from a single interactive session (LogonId 1002, session 3, pts/0): /etc/passwd, snap core18/core20/core22 container layers, and /opt/splunkforwarder/etc/passwd. All six executions shared the same binary hash, working directory (/home/tom), and parent PID (9497), confirming one connected session. The Splunk forwarder targeting was notable - the attacker was probing for service account credentials. The UserId:0 field in Sysmon was a setuid artefact from the su binary, not evidence of achieved root - clarified in Alert 04.		
Actions	Isolate paw-backup from the network immediately. Kill all processes under LogonId 1002 / session-3 / pts/0. Lock the tom account on all systems.		

Alert 04 18:33:02 UTC		paw-backup	TRUE POSITIVE
Title	Failed su to pawbackup - Privilege Escalation Attempt		
MITRE	T1548.003 - Abuse Elevation Control Mechanism: Sudo and Su		
Severity	High		
Analysis	From the same session-3/pts/0 context, tom (UID 1002, GID 1002) attempted su to the pawbackup service account and failed PAM authentication. This alert also resolved the UID confusion from Alert 03: su is a setuid binary and always runs with effective UID 0 regardless of who invokes it - Sysmon was reporting the binary's EUID, not tom's privilege level. Tom was a normal user at this point. The pawbackup account name indicated a backup service account with likely access to sensitive archive data.		
Actions	Lock the pawbackup account as a precaution. Audit its sudo rights and accessible directories. Search all log sources for subsequent successful su, sudo, SSH, or session events for the pawbackup account in the 18:33-18:40 window.		

Alert 05 18:38:21 UTC		paw-backup	TRUE POSITIVE
Title	Covert SFTP Exfiltration as pawbackup		
MITRE	T1048 - Exfiltration Over Alternative Protocol T1059.004 - Unix Shell		
Severity	Critical		
Analysis	Five minutes after the failed su, the attacker was operating as pawbackup (LogonId 1003, session 7, /home/pawbackup) - an alternate escalation path found during the unaccounted 18:33-18:38 window. The command <code>bash -c /usr/lib/openssh/sftp-server</code> was executed twice at 18:38:21 and 18:39:29. Legitimate sftp-server is only ever invoked automatically by sshd as a subsystem - never manually via bash. Manual invocation bypasses SSHD subsystem logging, making file transfers invisible to standard SSH session logs. Double execution (~68 seconds apart) suggested either a retry or two separate transfer sessions. As a backup server, accessible data likely included archives from across the entire organisation.		
Actions	Sever network connection immediately. Capture memory and disk image before any remediation. Pull all network flow logs from 18:38 UTC onward. Audit /home/pawbackup for staged files. Notify legal/compliance - GDPR 72-hour notification clock may be running from this point.		

Alert 06 18:47:54 UTC		PAW-TOM	FALSE POSITIVE
Title	ChatGPT Installer.exe Downloaded on PAW-TOM		
MITRE	T1204.002 - User Execution: Malicious File (ruled out)		
Severity	Informational		
Analysis	Sysmon EventID 11 fired when msedge.exe wrote ChatGPT Installer.exe to C:\Users\Administrator\Downloads\. Ruled FALSE POSITIVE on three grounds: (1) Parent process was legitimate Edge browser performing a standard download. (2) Zone.Identifier ADS was present - Windows automatically appends this to internet-sourced files as Mark of the Web; malware dropped via lateral movement typically lacks this marking. (3) 18 surrounding Splunk events showed entirely normal software acquisition via the official Microsoft portal, with no anomalous child processes or network callbacks. The alert rule fired correctly by design (broad: any executable to user-controlled directory) but the context was benign.		
Actions	Close as false positive. Rule tuning recommended: add suppression for known browser binaries when Zone.Identifier ADS is present. Low-priority follow-up to confirm no unexpected child processes spawned post-installation.		

Alert 07 18:53:22 UTC		alphvleaks (dark web)	TRUE POSITIVE
Title	BlackCat/ALPHV Public Extortion Post - 5-Day Deadline		
MITRE	T1657 - Financial Theft RaaS Double Extortion Methodology		
Severity	Critical		
Analysis	DarkSearchMe flagged a public post on the BlackCat/ALPHV leak site alphvleaks: 'PawPressMe - Data Exfiltrated, Payment Demanded.' The post claimed exfiltration of confidential documents, financial records, and internal correspondence, with a 5-day deadline. This is the expected conclusion of the double extortion playbook: exfiltrate first, then threaten public release. Total time from initial credential stuffing to public extortion post: approximately 26 minutes 44 seconds. BlackCat/ALPHV is a sophisticated RaaS group with Rust-based cross-platform ransomware and a consistent track record of following through on publication threats when deadlines are not met.		
Actions	Engage external IR retainer immediately. Notify CISO, legal counsel, and executive leadership. Do not pay without legal and IR guidance - sanctions implications must be assessed. Preserve the post URL and all content. Assess GDPR and other applicable data protection notification obligations urgently.		

Alert 08 19:03:52 UTC		PAW-TOM	TRUE POSITIVE
Title	RunRansom Scheduled Task Deployed on PAW-TOM		
MITRE	T1053.005 - Scheduled Task T1486 - Data Encrypted for Impact		
Severity	Critical		
Analysis	Sysmon EventID 1 and 11 captured the full chain: schtasks /Create /TN RunRansom /TR C:\Users\Public\ransom.exe /SC ONCE /ST 00:00 /RL HIGHEST /RU itadmin-tom /F, immediately followed by schtasks /Run /TN RunRansom. Parent process was svchost.exe -k netsvcs -p -s Schedule as NT AUTHORITY\SYSTEM (LogonId 0x3E7), confirming SYSTEM-level access already achieved. Output redirected to C:\Windows\Temp\yuYeaQvr.tmp to suppress console visibility. ransom.exe was pre-staged at C:\Users\Public - world-readable and world-writable, accessible regardless of which account executes the task.		
Actions	Do not reboot - capture memory forensics first. Disable itadmin-tom across all systems immediately. Delete the RunRansom task on all endpoints. Hunt for C:\Users\Public\ransom.exe environment-wide. Preserve disk image of PAW-TOM.		

Alert 09 19:08:09 UTC		PAW-LEO	TRUE POSITIVE
Title	RunRansom Deployed on PAW-LEO - Lateral Deployment Confirmed		
MITRE	T1053.005 T1570 - Lateral Tool Transfer T1486		
Severity	Critical		
Analysis	Identical deployment sequence confirmed on PAW-LEO exactly 4 minutes 17 seconds after PAW-TOM. Same command, same temp file names (yuYeaQvr.tmp / SNknzwdtu.tmp), same parent process chain, same execution account (itadmin-tom). This confirmed an automated deployment script pushing ransom.exe host by host. Leo was one of the four originally leaked credential accounts, consistent with the attacker having pre-obtained access credentials for this workstation prior to lateral movement.		
Actions	All Alert 08 actions apply equally to PAW-LEO. Isolate immediately. Initiate full environment-wide network isolation if not already done. Assume all Windows endpoints in the environment are targets for the same sequence.		

Alert 10 19:12:26 UTC		PAW-MARIE	TRUE POSITIVE
Title	RunRansom Deployed on PAW-MARIE		
MITRE	T1053.005 T1078 - Valid Accounts T1021 - Remote Services		
Severity	Critical		
Analysis	Propagation continues to PAW-MARIE at 19:12:26. Same task name, same ransom.exe path, same itadmin-tom execution account, same SYSTEM-level parent process chain. Marie's credentials were in the original credential dump. The automated rollout was methodically targeting every host associated with a leaked credential account. Environment status was escalated to assumed fully compromised at this point.		
Actions	Isolate PAW-MARIE. If not already initiated, begin full environment-wide network isolation now. Begin business continuity and disaster recovery procedures. Forensic imaging of all affected hosts before any remediation activity.		

Alert 11 19:16:43 UTC		PAW-TABITHA	TRUE POSITIVE
Title	RunRansom Deployed on PAW-TABITHA - Mass Encryption Phase		
MITRE	T1053.005 T1486 T1021		
Severity	Critical		
Analysis	Final confirmed deployment wave: PAW-TABITHA hit at 19:16:43. Tabitha was the fourth and final account in the original credential dump, completing the full circle - every credential obtained in Alert 01 had been operationalised against a corresponding host. The attacker completed the full double extortion playbook: initial access via credential reuse, post-exploitation enumeration, privilege escalation, covert data exfiltration, public extortion notice, and automated mass ransomware deployment. Total incident duration from first detection to final ransomware execution: approximately 54 minutes 41 seconds.		
Actions	<i>Full environment isolation. Shut down all lateral movement pathways (RDP, SMB, WinRM). Engage all IR, CISO, legal, and executive stakeholders simultaneously. Recover from clean, forensically verified backups only - no data on any compromised host can be trusted.</i>		

Silent tom SSH login inferred from absence of failure

In Alert 02, the SSH brute force logs showed failed attempts for leo, marie, and tabitha but not tom, who was in the same credential dump. sshd only logs failed attempts as 'invalid user' at the pre-authentication stage. A successful login produces an 'Accepted password' entry in a different log context. The absence of a failure entry for tom was precisely the indicator of success - confirmed three minutes later by Alert 03 showing an active session from /home/tom.

Resolving the UID 0 confusion in Sysmon telemetry

Alert 03 showed UserId:0, initially suggesting tom had achieved root. Alert 04 clarified this: su is a setuid binary and always runs with effective UID 0 regardless of who invokes it. Sysmon was reporting the binary's EUID, not tom's actual privilege level. Tom's real UID was 1002 throughout. This distinction was critical for correctly assessing the privilege escalation timeline and not overstating the attacker's position in the chain.

False positive identified correctly despite active incident proximity

Alert 06 (ChatGPT Installer) fired at 18:47 - right in the middle of the active intrusion. Three factors confirmed it was benign: (1) parent process was legitimate msedge.exe; (2) Zone.Identifier ADS was present - Windows applies this automatically to internet-sourced files as Mark of the Web, and malware dropped via lateral movement typically lacks this; (3) 18 surrounding Splunk events showed entirely normal software acquisition activity with no anomalous child processes or network callbacks. The pressure of an ongoing incident makes false positive discipline harder - this was the test within the test.

Covert SFTP invocation as a post-exploitation technique

Legitimate sftp-server is only ever invoked automatically by sshd as a subsystem - never manually by a user via bash -c. The manual invocation in Alert 05 bypassed SSHD subsystem logging entirely, making file transfers invisible to standard SSH session logs. The double execution ~68 seconds apart was consistent with either a retry or two separate exfiltration sessions, not with any legitimate administrative pattern.

Automated ransomware deployment identified from consistency signals

Deployment across four hosts (Alerts 08-11) was identified as scripted rather than manual: identical command-line strings, identical temp output file names, identical parent process chains (svchost Schedule service -> cmd.exe -> schtasks.exe), and consistent ~4-minute intervals between each host being hit. Staging ransom.exe in C:\Users\Public was deliberate - world-readable and world-writable, accessible regardless of execution account.

INDICATORS OF COMPROMISE

Indicator	Value
Attacker IP	194.50.16.198
Initial access credential	tom@pawpress.me : ILoveLasagn@
Linux host compromised	paw-backup
Windows hosts	PAW-TOM, PAW-LEO, PAW-MARIE, PAW-TABITHA
Ransomware binary	C:\Users\Public\ransom.exe
Scheduled task name	RunRansom
Task file path	C:\Windows\System32\Tasks\RunRansom
Temp output files	C:\Windows\Temp\yuYeaQvr.tmp SNknzwdw.tmp
Execution account	itadmin-tom (NT AUTHORITY\SYSTEM parent)
Exfil technique	bash -c /usr/lib/openssh/sftp-server (covert SFTP)
Exfil account	pawbackup (LogonId 1003, session 7)
ransom.exe SHA256	4B679CCC4E0E84A9EDDC24362EA4A86835597A90D94A1AE0EA905D7BCD9F771C
schtasks.exe MD5	2F6CE97FAF2D5EEA919E4393BDD416A7
cmd.exe MD5	911D039E71583A07320B32BDE22F8E22
Threat actor	BlackCat / ALPHV (RaaS group)
Leak site	alphvleaks
Source breach site	WatchingCatsLounge.thm

CONCLUSIONS

This incident demonstrates how a single weak, reused password in a third-party breach can serve as the entry point for a complete ransomware deployment in under an hour. The attacker moved with professional speed and automation: 96 seconds from credential exposure to first attack, 13 minutes from initial access to data exfiltration, and 43 minutes to ransomware executing on the first endpoint.

From an analyst perspective, the most instructive moments were: recognising the silent tom SSH login from an absence of evidence rather than positive confirmation; correctly interpreting the setuid UID artefact in Sysmon; and ruling out the ChatGPT installer as a false positive despite its temporal proximity to a live incident under pressure. Each required looking beyond individual alert fields to understand the full context of the event.

The lab reinforced that effective SOC analysis is less about reacting to individual alerts and more about building a coherent narrative across a chain of events - recognising when alerts are fragments of the same story, and escalating with appropriate urgency when that story is an active intrusion in progress.